Modelado de amenazas de un sitio web
Caso: EventosU

Douglas Daniel Pérez Hernández

Carlos Daniel Martínez García

12 de noviembre de 2026

Analizo el diseño de EventosU para identificar amenazas antes de programarlo y convertir los riesgos principales en requisitos que puedan verificarse.

2. Alcance, activos y supuestos

Alcance. Incluyo el sitio React/CDN, API Node.js con JWT, PostgreSQL, bucket, panel /admin, app de puerta y las interfaces con Entra ID, pagos y correo. Reviso registro, recuperación, inscripción, pago, emisión y uso del QR, afiches y exportaciones. No evalúo código ni realizo ataques reales. Quedan fuera la operación interna de proveedores, los datos de tarjetas y el acceso físico que no depende de la aplicación.

Activo	Valor para la universidad
Identidad, credenciales y sesión	Evitar suplantación y mantener la confianza de los usuarios.
Datos de inscritos: nombre, correo, carné y teléfono	Proteger información personal y evitar exportaciones ajenas.
Órdenes y estado de pago	Mantener ingresos y emitir entradas solo por pagos confirmados.
QR y estado de uso	Evitar duplicados, fraude y conflictos en puerta.
Usuarios y roles	Limitar quién administra, exporta y valida entradas.
Catálogo y afiches	Publicar información correcta sin contenido activo malicioso.
Disponibilidad de API y base de datos	Permitir inscripción y acceso durante los eventos.
Auditoría y CSV	Investigar cambios y controlar la salida de información.

2.1 Supuestos del modelo

• El caso no define controles completos. Las amenazas son posibilidades del diseño, no vulnerabilidades comprobadas. La probabilidad se estima antes de aplicar las mitigaciones propuestas.

• Supongo conexión a Internet en puerta y validación en línea. El QR es una credencial al portador; propongo un valor opaco, aleatorio, ligado al evento y de un solo uso. No incluyo modo offline.

• Supongo órdenes de pago con identificador único. La pasarela puede firmar webhooks y proporcionar un ID de evento; la integración deberá adaptarse al contrato real del proveedor.

• Para el login institucional propongo OIDC sobre OAuth 2.0. OAuth 2.0 por sí solo no define la identidad. El registro local y la recuperación siguen disponibles para público externo.

• El organizador solo gestiona sus eventos. El personal de puerta valida únicamente los eventos asignados. /admin comparte el login, pero sus permisos se verifican en la API.

• Agrego D03 como servicio de auditoría separado. Propongo retención de 90 días, sin secretos, y acceso de lectura limitado. Estos valores deberán aprobarse según la política de la universidad.

• El bucket contiene afiches y CSV en prefijos separados. Propongo CSV privado con retención de 24 horas y enlaces firmados de 5 minutos. Los afiches se sirven desde un origen separado.

• P01 representa React ejecutado en el navegador; P05 representa el CDN que entrega sus archivos. P02 es la ruta /admin del mismo sitio. F13 y F14 resumen las solicitudes del navegador del organizador a la API.

• LC1 agrupa dispositivos y el frontend público como zona no confiable para la API; no supone que el CDN pertenezca al dispositivo. LC2 es la aplicación en nube; LC3, los datos administrados; LC4, LC5 y LC6 son proveedores externos.

• La aceptación de I04 es una decisión del modelo, pendiente de ratificación por el dueño funcional. No implica que un responsable real ya haya aprobado el riesgo.

3. DFD nivel 0 - Contexto

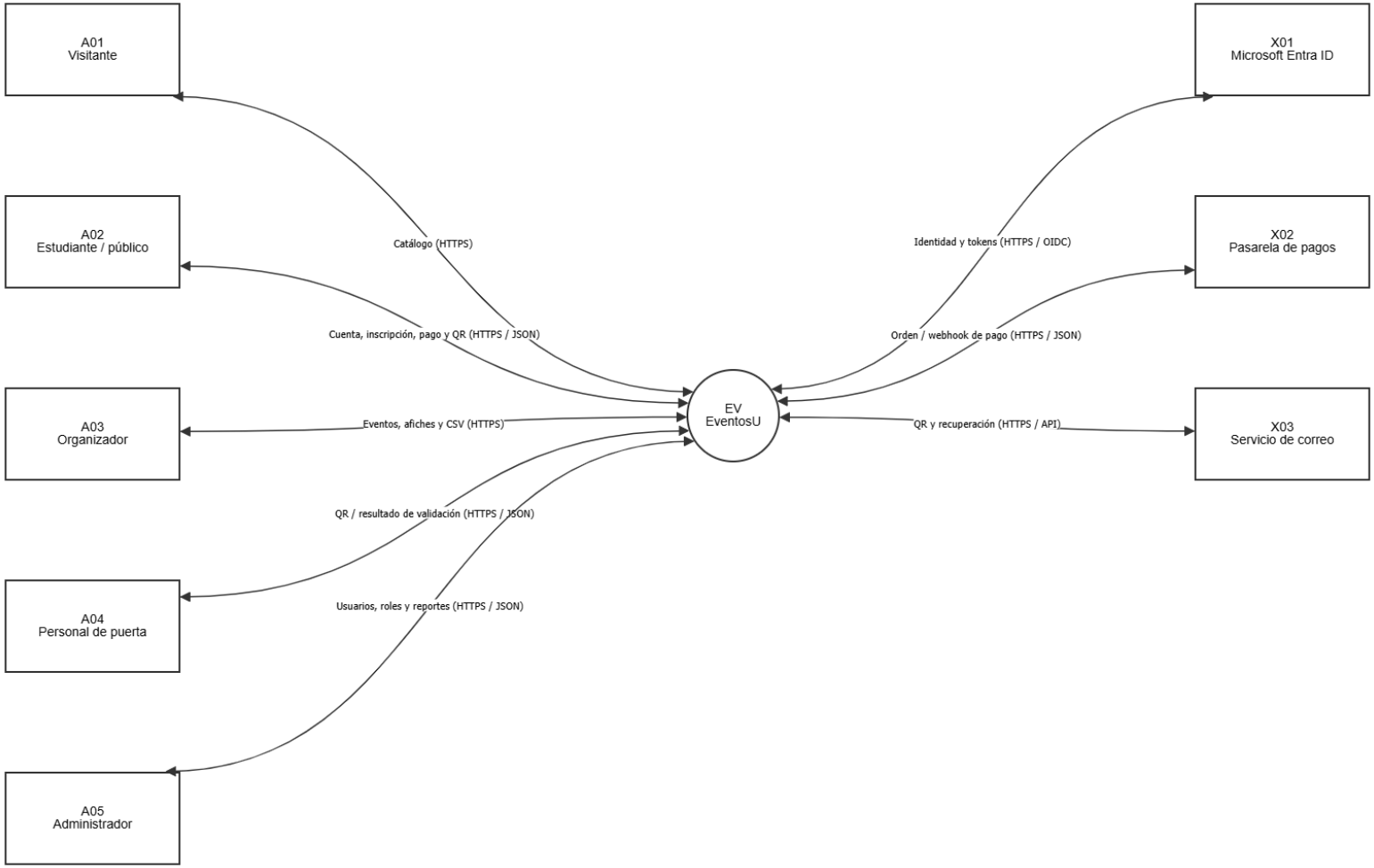


Figura 1. Diagrama abierto y exportado desde Threat Dragon 2.6.2. EventosU se representa como un único proceso. Las flechas dobles resumen solicitud y respuesta; el detalle del webhook y del correo se separa en el nivel 1.

3.1 DFD nivel 1 - Componentes y límites

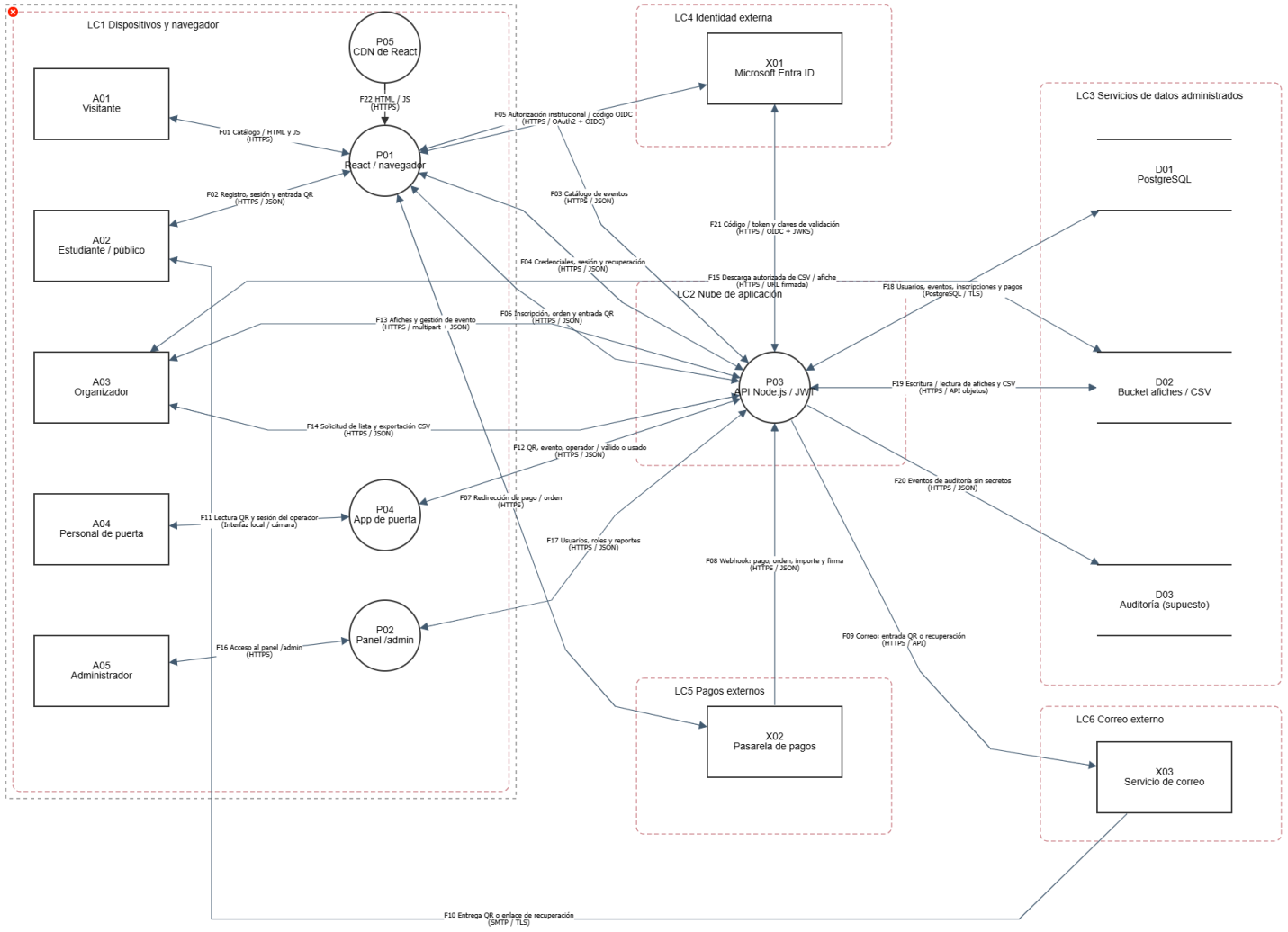


Figura 2. Exportación de Threat Dragon. Rectángulo: actor externo; círculo: proceso; líneas paralelas: almacén; contorno discontinuo: límite de confianza. La imagen PNG original permite ampliar las etiquetas.

3.2 Catálogo de flujos

ID	Origen → destino	Dato y protocolo
F01	A01 → P01 (ida/vuelta)	Catálogo / HTML y JS (HTTPS)
F02	A02 → P01 (ida/vuelta)	Registro, sesión y entrada QR (HTTPS / JSON)
F03	P01 → P03 (ida/vuelta)	Catálogo de eventos (HTTPS / JSON)
F04	P01 → P03 (ida/vuelta)	Credenciales, sesión y recuperación (HTTPS / JSON)
F05	P01 → X01 (ida/vuelta)	Autorización institucional / código OIDC (HTTPS / OAuth2 + OIDC)
F06	P01 → P03 (ida/vuelta)	Inscripción, orden y entrada QR (HTTPS / JSON)
F07	P01 → X02 (ida/vuelta)	Redirección de pago / orden (HTTPS)
F08	X02 → P03	Webhook: pago, orden, importe y firma (HTTPS / JSON)
F09	P03 → X03	Correo: entrada QR o recuperación (HTTPS / API)
F10	X03 → A02	Entrega QR o enlace de recuperación (SMTP / TLS)
F11	A04 → P04 (ida/vuelta)	Lectura QR y sesión del operador (Interfaz local / cámara)
F12	P04 → P03 (ida/vuelta)	QR, evento, operador / válido o usado (HTTPS / JSON)

En F11 el QR se captura mediante cámara y se muestra el resultado localmente; el intercambio de red real de validación es F12.

3.3 Flujos de gestión y cruces de confianza

ID	Origen → destino	Dato y protocolo
F13	A03 → P03	Afiches y gestión de evento (HTTPS / multipart + JSON)
F14	A03 → P03	Solicitud de lista y exportación CSV (HTTPS / JSON)
F15	A03 → D02	Descarga autorizada de CSV / afiche (HTTPS / URL firmada)
F16	A05 → P02	Acceso al panel /admin (HTTPS)
F17	P02 → P03	Usuarios, roles y reportes (HTTPS / JSON)
F18	P03 → D01	Usuarios, eventos, inscripciones y pagos (PostgreSQL / TLS)
F19	P03 → D02	Escritura / lectura de afiches y CSV (HTTPS / API objetos)
F20	P03 → D03	Eventos de auditoría sin secretos (HTTPS / JSON)
F21	P03 → X01	Código / token y claves de validación (HTTPS / OIDC + JWKS)
F22	P05 → P01	Archivos React: HTML / JS (HTTPS)

Cruces analizados. LC1-LC2: F03, F04, F06, F12, F13, F14 y F17. LC1-LC4: F05. LC5-LC2: F08. LC1-LC3: F15. LC2-LC3: F18-F20. LC2-LC4: F21. Entre otros, S01, S02, S03, T01, T02, T03, I01 y E01 están asociados a flujos que cruzan un límite.

Los controles de TLS, autenticación y permisos del diagrama son requisitos propuestos; su presencia en la etiqueta no acredita una implementación segura.

4. Tabla de amenazas

STRIDE: S = suplantación; T = manipulación; R = repudio; I = divulgación de información; D = denegación de servicio; E = elevación de privilegios.

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
S01 / F08 / S	Un atacante envía un webhook falso a la API y obtiene una inscripción pagada sin realizar el cobro. **I=3; P=3; riesgo=9** I: permite fraude de entradas. P: el endpoint recibe solicitudes públicas.	**Mitigar**. Verificar firma sobre el cuerpo original, timestamp con tolerancia de 5 minutos y emisor; rechazar mensajes inválidos antes de actualizar pagos. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
S02 / F04 / S	Un atacante usa credenciales filtradas en el login local y obtiene la cuenta y las entradas de otro usuario. **I=3; P=2; riesgo=6** I: expone cuenta y entradas. P: requiere credenciales válidas reutilizadas.	**Mitigar**. Limitar intentos por cuenta e IP, detectar credential stuffing y exigir MFA a roles privilegiados; probar bloqueo progresivo. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
S03 / F05 / S	Un atacante presenta un token de otro tenant o destinado a otra aplicación y obtiene una sesión institucional. **I=3; P=2; riesgo=6** I: permite identidad institucional falsa. P: exige una validación incompleta del token.	**Mitigar**. Usar OIDC sobre OAuth 2.0, código con PKCE y state/nonce; validar firma, issuer, audience, expiración y tenant autorizado. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
S04 / F11 / S	Un atacante copia un QR de un correo ajeno y llega primero a puerta para obtener el acceso de la víctima. **I=2; P=2; riesgo=4** I: afecta una entrada y desplaza al dueño. P: necesita conseguir el QR vigente.	**Mitigar**. QR opaco aleatorio de al menos 128 bits, sin datos personales, ligado al evento; permitir revocar y reemitir y verificar identidad cuando el evento lo requiera. **Estado:** Abierta - control propuesto

4. Tabla de amenazas (continuación)

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
T01 / F12 / T	Dos personas presentan el mismo QR al mismo tiempo; ambas reciben válido si la API separa consulta y actualización. **I=3; P=3; riesgo=9** I: permite accesos duplicados. P: dos solicitudes paralelas bastan si no hay atomicidad.	**Mitigar**. Validar pago, evento y uso en una sola transacción; UPDATE condicional de usado=false con retorno de una sola fila; un único ganador bajo concurrencia. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
T02 / F06 / T	Un usuario modifica importe, moneda o estado en la inscripción y obtiene una entrada pagando menos o nada. **I=3; P=3; riesgo=9** I: altera directamente la recaudación. P: el cliente controla el cuerpo de su solicitud.	**Mitigar**. Calcular precio y moneda en servidor; ignorar campos de estado del cliente y conciliar webhook con orden, importe, moneda y comercio esperados. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
T03 / F14 / T	Un inscrito guarda un nombre que empieza con fórmula; al abrir el CSV, el organizador ejecuta contenido en su hoja de cálculo. **I=3; P=2; riesgo=6** I: compromete el entorno del organizador. P: requiere exportar y abrir en un visor que evalúe fórmulas.	**Mitigar**. Exportar todos los campos como texto seguro; neutralizar =,+,-,@ y prefijos de control tras normalizar; probar en el visor usado por la universidad. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
T04 / F13 / T	Un organizador malicioso sube un SVG con script como afiche y altera la sesión de quien lo visualiza. **I=3; P=2; riesgo=6** I: puede robar sesión o cambiar eventos. P: exige admitir contenido activo.	**Eliminar**. Excluir SVG y HTML; admitir solo JPEG/PNG, decodificar y recodificar en servidor, limitar tamaño a 5 MB y servir desde origen separado sin credenciales. **Estado:** Abierta - control propuesto

4. Tabla de amenazas (continuación)

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
R01 / F08 / R	Un usuario niega un pago o el atacante repite una notificación y la universidad no puede reconstruir qué evento cambió la inscripción. **I=2; P=2; riesgo=4** I: dificulta resolver disputas. P: depende de registros insuficientes.	**Mitigar**. Registrar ID único del proveedor, orden, resultado de firma, transición y correlación; deduplicar eventos y conservar auditoría protegida sin secretos. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
R02 / F12 / R	Un empleado niega haber validado una entrada irregular y no existe relación entre el escaneo y su cuenta. **I=2; P=2; riesgo=4** I: impide atribuir accesos indebidos. P: ocurre si se comparten cuentas o faltan logs.	**Mitigar**. Cuentas individuales de puerta; registrar operador, evento, identificador resumido de entrada, hora y resultado en auditoría de solo anexado. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
R03 / F14 / R	Un organizador descarga el listado y niega la exportación; la universidad no puede rastrear la salida de datos. **I=3; P=2; riesgo=6** I: impide investigar exposición de datos personales. P: requiere falta de auditoría de exportaciones.	**Mitigar**. Auditar solicitante, evento, cantidad de filas, archivo y descarga; restringir borrado y alertar sobre volúmenes atípicos. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
R04 / F17 / R	Un administrador cambia roles y luego niega el cambio porque puede borrar el registro en el mismo sistema. **I=3; P=2; riesgo=6** I: oculta la elevación de privilegios. P: requiere acceso administrativo y logs alterables.	**Mitigar**. Enviar cambios de roles con valores anterior/nuevo a un servicio de auditoría separado; impedir borrado a la identidad de la API y del administrador funcional. **Estado:** Abierta - control propuesto

4. Tabla de amenazas (continuación)

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
I01 / F15 / I	Un organizador cambia el identificador de exportación o reutiliza un enlace público y obtiene el CSV de otro evento. **I=3; P=3; riesgo=9** I: revela nombre, correo, carné y teléfono en conjunto. P: basta manipular una referencia si falta autorización.	**Mitigar**. Autorizar por usuario y evento antes de generar y descargar; bucket privado, URL firmada de 5 minutos tras autorización y borrado del CSV en 24 horas. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
I02 / F04 / I	Un atacante aprovecha un XSS en el navegador y lee el JWT persistido para secuestrar sesiones. **I=3; P=2; riesgo=6** I: permite actuar como la víctima. P: necesita una inyección ejecutable.	**Mitigar**. Evitar almacenamiento persistente del token; preferir cookie HttpOnly Secure SameSite con defensa CSRF; CSP restrictiva y eliminación de HTML no confiable. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
I03 / D03 / I	Un operador consulta logs con JWT, enlaces QR o tokens de recuperación y obtiene acceso a cuentas o entradas. **I=3; P=2; riesgo=6** I: los secretos permiten suplantar usuarios. P: exige acceso a logs que contengan valores sensibles.	**Mitigar**. Redactar Authorization, cookies, QR y tokens antes de registrar; acceso mínimo, retención de 90 días y prueba con valores señuelo. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
I04 / F01 / I	Un visitante automatiza la lectura del catálogo y copia nombres, fechas y precios publicados. **I=1; P=2; riesgo=2** I: los datos ya son públicos y no incluyen inscritos. P: la automatización es sencilla pero el interés es incierto.	**Aceptar**. Aceptar solo la copia del catálogo público; responsable: dueño funcional de EventosU; revisar por evento o en 90 días. Mantener límites de lectura; si hay caída se aplica D01. **Estado:** Aceptada en el modelo

4. Tabla de amenazas (continuación)

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
D01 / F03 / D	Un bot satura búsquedas costosas del catálogo y deja la API sin capacidad para usuarios legítimos. **I=2; P=3; riesgo=6** I: interrumpe consultas e inscripciones temporalmente. P: la ruta es pública y automatizable.	**Mitigar**. Cachear catálogo, paginar máximo 100 resultados, limitar por IP y fijar timeout de consultas; verificar con carga controlada. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
D02 / F13 / D	Un organizador sube imágenes comprimidas con dimensiones enormes y agota memoria del contenedor. **I=2; P=2; riesgo=4** I: interrumpe el servicio mientras se recupera. P: requiere una cuenta de organizador.	**Mitigar**. Limitar bytes, dimensiones y píxeles decodificados; procesar en worker con memoria y timeout acotados; rechazar imagen fuera de límite. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
D03 / F14 / D	Un organizador solicita exportaciones repetidas y consume conexiones y CPU de PostgreSQL. **I=2; P=2; riesgo=4** I: retrasa pagos y validación de acceso. P: requiere sesión con permiso de exportación.	**Mitigar**. Una exportación activa por organizador, cola con cuota, límite de filas y timeout; separar pool y probar saturación sin bloquear escaneo. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
D04 / F11 / D	Un atacante envía muchos QR aleatorios a validación y provoca filas largas al agotar la capacidad de puerta. **I=3; P=2; riesgo=6** I: impide ingreso durante el evento. P: requiere llegar al endpoint y superar autenticación si existe.	**Mitigar**. Autenticar dispositivo y operador, limitar por evento/operador/IP, rechazar formatos inválidos antes de consultar y reservar capacidad para puerta. **Estado:** Abierta - control propuesto

4. Tabla de amenazas (continuación)

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
E01 / F17 / E	Un estudiante llama directamente endpoints administrativos o manda role=admin y obtiene control de usuarios y roles. **I=3; P=3; riesgo=9** I: compromete toda la administración. P: es trivial invocar la API si solo se oculta /admin.	**Mitigar**. Denegar por defecto en API; autorización por acción y recurso, ignorar role del cliente y MFA para administradores; probar todos los roles. **Estado:** Abierta - control propuesto

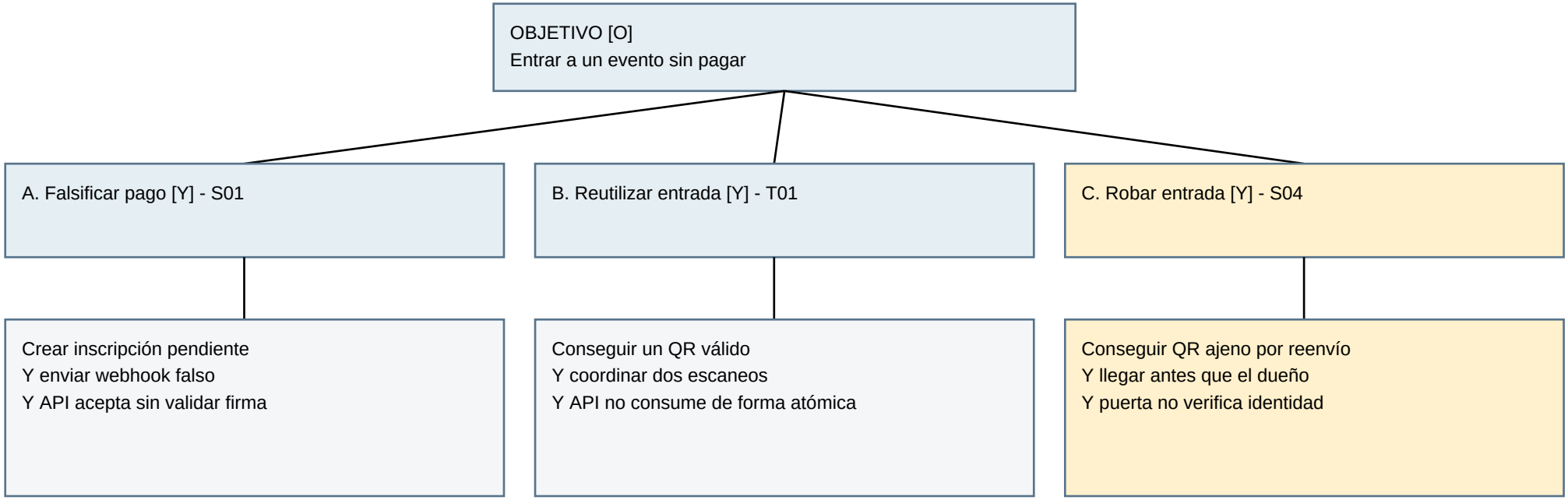
ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
E02 / F06 / E	Un usuario cambia el ID de inscripción y descarga o cancela la entrada de otra persona. **I=3; P=2; riesgo=6** I: afecta acceso y datos de terceros. P: requiere una referencia ajena y ausencia de control de propiedad.	**Mitigar**. Derivar usuario desde la sesión; verificar propietario en cada operación de inscripción, pago y QR, incluso con UUID. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
E03 / P03 / E	Un atacante explota una dependencia vulnerable de Node.js y obtiene ejecución con la identidad del contenedor. **I=3; P=2; riesgo=6** I: expone secretos y servicios conectados. P: necesita una dependencia vulnerable alcanzable.	**Mitigar**. SCA de lockfile e imagen con bloqueo de vulnerabilidades explotables altas/críticas; contenedor no root, sin privilegios y secretos de alcance mínimo. **Estado:** Abierta - control propuesto

ID / elemento / STRIDE	Escenario y priorización	Respuesta, mitigación y estado
E04 / F13 / E	Un organizador manipula la clave de objeto y sobrescribe afiches o CSV de otro organizador usando permisos amplios del bucket. **I=3; P=2; riesgo=6** I: altera archivos y listas de terceros. P: exige credenciales de organizador y validación débil de claves.	**Mitigar**. Generar claves en servidor, separar prefijos de afiches y CSV, comprobar dueño/evento y limitar IAM de carga y lectura por función. **Estado:** Abierta - control propuesto

5. Árbol de ataque: entrar a un evento sin pagar

El nodo O se cumple con cualquiera de sus ramas. El nodo Y exige todas sus condiciones. El árbol representa el diseño antes de implementar los controles.



Camino más barato: C. Si el QR funciona como credencial al portador y no se contrasta identidad, basta obtener una captura reenviada y presentarse primero. No requiere romper firmas ni coordinar concurrencia. El costo depende de conseguir el QR; no afirmo que siempre sea el más probable. Si se controla la identidad, este camino deja de ser suficiente.

A se corta autenticando el webhook y conciliando la orden. B se corta con consumo atómico. C se reduce con reemisión/revocación y control de identidad cuando corresponda. En ningún caso mostrar una imagen QR demuestra por sí mismo que el pago sea válido.

6. Matriz de riesgo 3 × 3

Uso riesgo = impacto × probabilidad. Califico el riesgo inicial, sin dar por implementadas las mitigaciones. Las estimaciones expresan juicio de diseño y deben revisarse cuando se conozca la implementación.

Valor	Impacto	Probabilidad
1 - bajo	Afectación limitada a información pública o molestia menor, sin pérdida relevante.	Requiere condiciones excepcionales, acceso especializado o varios obstáculos.
2 - medio	Afecta un usuario o evento, o causa una interrupción temporal recuperable.	Requiere cuenta, QR, credenciales o una condición adicional concreta.
3 - alto	Fraude de ingresos, datos personales en volumen, administración o ingreso del evento.	Se ejecuta con peticiones sencillas a funciones expuestas si falta el control.

Impacto / probabilidad	P1	P2	P3
I3	3 - medio	6 - alto	9 - crítico
I2	2 - bajo	4 - medio	6 - alto
I1	1 - bajo	2 - bajo	3 - medio

Bandas: 1-2 bajo; 3-4 medio; 6 alto; 9 crítico. No hay puntuaciones 5, 7 u 8 en esta matriz. Las justificaciones de impacto y probabilidad aparecen en cada amenaza.

Orden principal: S01, T01, T02, I01 y E01 tienen 9 puntos. Deben resolverse antes de aceptar pagos y abrir el evento. Los riesgos de 6 también requieren control antes de producción; la selección de cinco responde a la trazabilidad pedida en el ejercicio.

Aceptación: I04 tiene 2 puntos y solo cubre copiar información publicada. Responsable propuesto: dueño funcional de EventosU. Revisión: antes de cada evento o en 90 días. Si el scraping afecta disponibilidad, deja de cubrirlo esta aceptación y se trata como D01.

7. Trazabilidad de las cinco amenazas críticas

Fijo OWASP ASVS **4.0.3** para mantener identificadores estables; no lo presento como la versión más reciente. Los requisitos siguientes están parafraseados. El vínculo ASVS orienta el objetivo; la condición de aceptación concreta corresponde a EventosU. Las pruebas quedan propuestas para cuando exista el sistema.

S01 - ASVS 11.1.5

Validaciones de negocio frente a los riesgos identificados. SEC-01. Implementar autenticación y deduplicación del webhook.

Verificación: DAST con casos autenticados en CI y prueba manual del contrato de firma.

Aceptación: Firma ausente, inválida o timestamp mayor a 5 min: rechazar sin cambiar pago ni emitir QR. Mensaje válido: una transición. Repetir el mismo ID diez veces: una sola entrada.

T01 - ASVS 11.1.6

Evitar carreras y errores entre verificación y uso. SEC-02. Consumir el QR en una operación atómica por evento.

Verificación: Prueba manual de concurrencia reproducible con cliente de carga; adjuntar resultados al pipeline.

Aceptación: Enviar 20 validaciones paralelas del mismo QR pagado: exactamente una válida y 19 ya usado. QR impagado o de otro evento: cero válidas.

T02 - ASVS 11.1.1 y 11.1.5

Respetar secuencia de negocio y validar riesgos de fraude. SEC-03. Calcular precios en servidor y conciliar orden con pasarela.

Verificación: DAST con alteración de campos y webhooks de prueba firmados.

Aceptación: Precio/moneda alterados en cliente no cambian el total. Un webhook firmado con importe, moneda u orden distintos no marca pagado ni emite QR.

7.1 Trazabilidad y controles del pipeline

I01 - ASVS 4.2.1 y 4.1.3

Evitar IDOR y aplicar mínimo privilegio a datos y archivos. SEC-04. Autorizar generación/descarga del CSV y cerrar acceso público.

Verificación: DAST entre dos organizadores + IaC para política del bucket.

Aceptación: Organizador A no genera ni descarga CSV de B (403/404). Acceso anónimo denegado; enlace firmado expira a los 5 min. IaC falla si se permite lectura/listado público del prefijo CSV.

E01 - ASVS 4.1.1 y 4.3.1

Aplicar permisos en servidor y MFA en administración. SEC-05. Centralizar autorización administrativa y exigir MFA.

Verificación: DAST con matriz de roles y prueba manual de MFA.

Aceptación: Estudiante/organizador/puerta reciben 403 al gestionar roles; enviar role=admin no eleva permisos. Solo administrador con MFA completa la acción; denegar si falta rol o sesión.

Criterio del pipeline. Ejecutar SAST y SCA por cambio; IaC antes de desplegar; DAST en ambiente de pruebas con datos ficticios y cuentas por rol. Los casos críticos bloquean la promoción si fallan. Conservar resultados asociados al commit. SAST o un escaneo DAST genérico no demuestran por sí solos la firma de webhooks, la autorización por recurso ni la atomicidad del QR.

Cierre de amenazas. Mantener cada amenaza abierta hasta tener control implementado, prueba aprobada y revisión. T04 propone eliminar formatos activos, pero permanece abierta hasta comprobar la restricción. I04 se registra como aceptación del modelo, sujeta a ratificación. No reporto riesgos residuales numéricos sin comprobar los controles.

8. Conclusiones

Antes de programar EventosU, cambiaría la forma en que se confirma el pago: la API debe confiar en una notificación autenticada y conciliada con la orden, y nunca en el estado que envía el navegador. También definiría desde el inicio la transacción que valida y consume el QR, porque una consulta seguida de una actualización puede permitir accesos duplicados.

Separaría los permisos de usuarios, organizadores, personal de puerta y administradores en la API. Protegería los CSV por evento y mantendría los afiches separados de los archivos con datos personales. Evitaría contenido activo en las imágenes y no guardaría el token de sesión de forma persistente y accesible desde JavaScript.

Mi prioridad sería resolver los cinco riesgos críticos y después verificar los controles de los riesgos altos. El modelado permite decidir qué probar antes de implementar. Lo actualizaría cuando se elija la pasarela, se defina el manejo de sesión y se confirme cómo funcionará el ingreso a los eventos.

Referencias

OWASP ASVS 4.0.3 - control de acceso

OWASP ASVS 4.0.3 - lógica de negocio

OWASP Threat Dragon - diagramas

OWASP Threat Modeling Cheat Sheet

Base del caso: enunciado de la tarea de modelado de amenazas de EventosU. No se utilizó un sistema real ni se ejecutaron pruebas de seguridad.